



PDI 2026 | TRILHA 06 | ATIVIDADE 1

Guardrails e **anti-prompt-injection** em automacoes com LLM

Autor: PDI Marcos Luciano - marcosluciano.rodrigues@v4company.com

Unidade: FV Marketing / V4 Company: Automação & Infraestrutura

Módulo: 06 | Governanca de IA e Seguranca

Data: Setembro 2026

Status: **NÃO PUBLICADO** · Desenvolvido / Homologação pendente

Versão: 1.0

pdi-governanca-ia-seguranca-a1

1. Contexto

Resumo de leads, triagem de tickets e geracao de copy consomem texto livre de usuarios, paginas, e-mails e planilhas. Cada fonte externa e um vetor: o modelo nao distingue com seguranca instrucao de dado, entao qualquer texto na janela vira candidato a comando.

Esta atividade padroniza a barreira em **5 camadas** para que cada novo fluxo com LLM nasca com teto de dano conhecido e auditavel, alinhado ao OWASP Top 10 para LLMs.

2. Diagnóstico

Injecao direta ("ignore as instrucoes anteriores") e indireta (instrucao oculta no documento que o bot resume) desviam o modelo, vazam contexto do system prompt ou disparam acao indevida via ferramenta conectada. Saida sem contrato vira execucao sem dono (OWASP LLM01 e LLM02).

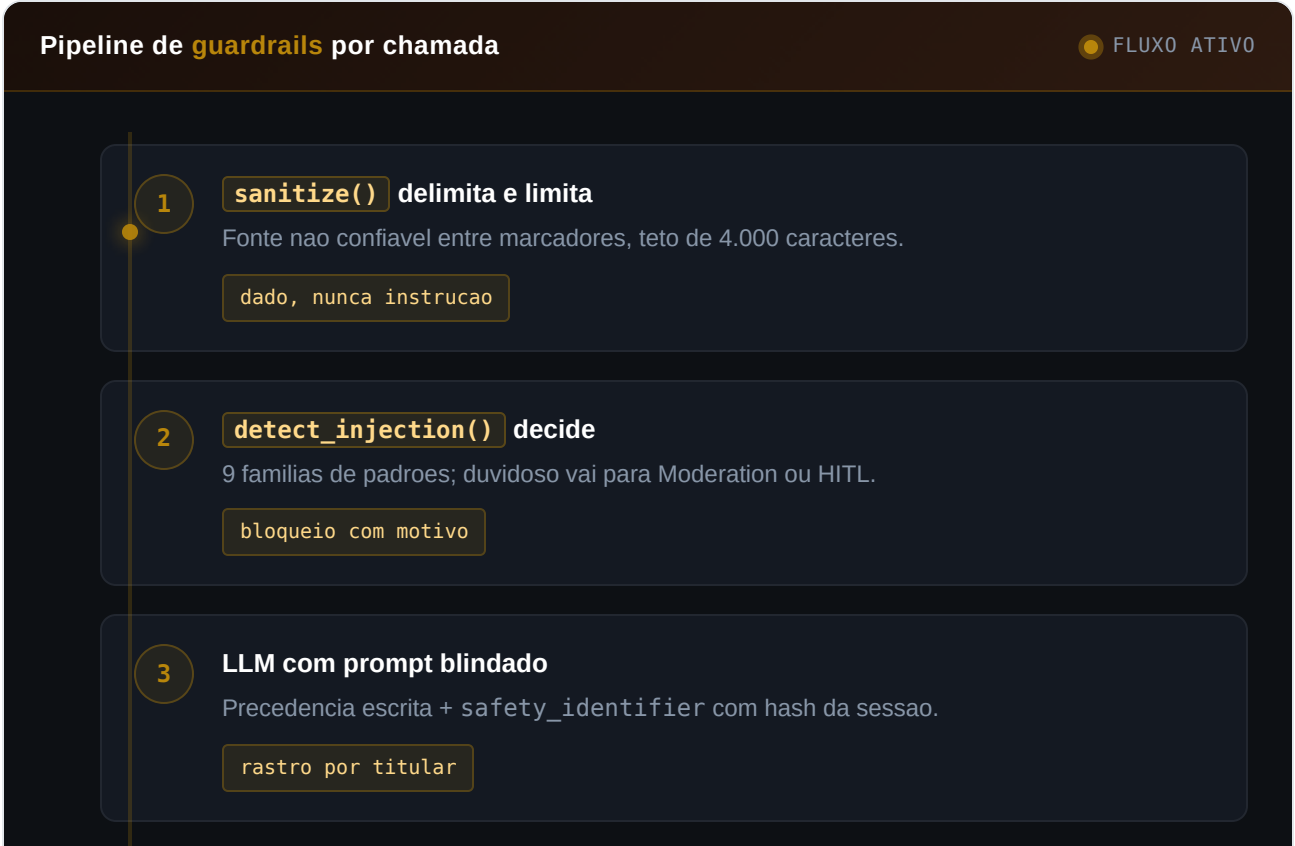
VETOR	EXEMPLO	BARREIRA
Direta	Usuario digita ordem de exfiltrar	<code>detect_injection</code> + Moderation
Indireta	Texto oculto no documento resumido	Delimitador + detector
Output inseguro	Chamada de ferramenta nao validada	<code>validate_output</code> + HITL

3. Solução

Proxy de guardrails em Python puro com 3 funcoes (sanitize, detect_injection com 9 familias de padroes, validate_output por contrato JSON), system prompt blindado com precedencia escrita, `safety_idenfifier` com hash por sessao e HITL obrigatorio em escrita em CRM, Ads, banco ou mensagem ao cliente.

- Standard com modelo de ameaca, 6 camadas e red team de 60 casos
- Codigo com self-test de 9 casos, todos passando
- Checklist de ativacao por automacao

4. Como funciona



4

validate_output()

 valida

So passa JSON com as chaves do contrato, sem HTML ativo.

fora do contrato, descarta

5

HITL + auditoria

Acao sensivel exige humano; tudo vai para a trilha.

dano irreversivel eliminado

guardrail_proxy.py | Python puro, sem dependencias

self-test: 9/9 passando

5. Entregas

ARQUIVO	CONTEUDO
1-standards/STANDARD-GUARDRAILS-LLM.md	Ameaca, 6 camadas, red team, proibicoes
2-implementacao/guardrail_proxy.py	Proxy executavel com self-test 9/9
2-implementacao/CHECKLIST-GUARDRAILS.md	Ativacao por automacao, 8 itens
7-apresentacao/	Deck de 12 slides, demo, roteiro com 5 Q and A, este relatorio em HTML, DOCX e PDF

6. Métricas de sucesso

METRICA	ATUAL	META
Bloqueio em bateria de 60 injecoes	0% (sem protecao)	95% (meta)
Latencia p95 adicionada	nao medida	abaixo de 150 ms (meta)
Alto risco com HITL	0%	100% (meta)

Status: Desenvolvido em Setembro 2026, homologacao pendente: ligar Moderation API no piloto de resumo de tickets e publicar o primeiro placar adversarial.